

기술 제안서

비개발자 임직원용 업무 에이전트 개발 플랫폼

Claude · GPT · Gemini 바이트코딩 환경의
샌드박스 · 통제/보안 · 거버넌스 구축

2026-09-07

대상 사내 IT · 보안 담당, AI 도입 TF

전제 사내 IdP 로 Keycloak 운영 중 (realm itgrims)

“바이브코딩 통제 솔루션”이라는 **단일 제품은 없다.**
강제 지점 4개를 만들고, 그 외에는 자유를 준다.

무엇을 통제하나

모델 접근 · 데이터 · 자격증명 · 실행권한 · 배포 · 비용.
도구를 통제하는 게 아니라 **이 6가지가 지나가는 길목**을 통제한다.

핵심 원칙

비개발자에게 **만들 자유는 최대한, 권한은 한 톨도** 주지 않는다. 권한은 실행 시점에 에이전트가 사용자로부터 빌린다.

기존 자산 재활용

운영 중인 **Keycloak** 을 그대로 쓴다. 새 IAM 도입 불필요. business 클레임이 에이전트에도 자동 적용된다.

권고 — 안 B(자체호스팅 하이브리드). 단 **AI 게이트웨이부터 2주** 안에 착수하고, 8주간은 합성 데이터로만 PoC. **전담 인력 1.5~2명 확보가 전제조건**이다.

①

작성 환경

원격 워크스페이스
+ 샌드박스 + 이그레스 allowlist
개인 PC 금지

②

AI 게이트웨이

LiteLLM 자체호스팅
모델 allowlist · 예산 캡
아무도 벤더 키를 못 가짐

③

도구 · 데이터 관문

MCP 게이트웨이 + Keycloak
에이전트는 사용자 권한만 상속

④

승격 게이트

템플릿 레포 · 자동심사 CI
운영 반영은 통과분만

02 시장에 단일 제품이 없다

문제 정의

지금 살 수 있는 제품은 두 종류인데, **각각 문제의 절반씩만 덮는다.**

제품군	예	덮는 범위	안 덮는 것
개발 도구 관리	Claude Code managed settings Codex requirements.toml GitHub Copilot 정책	임직원이 코드를 만드는 순간	만들어진 에이전트가 사내 DB 를 긁어가는 것
에이전트 런타임 거버넌스	Microsoft Agent 365 AWS Bedrock AgentCore Google Gemini Enterprise	배포된 에이전트가 돌아가는 순간	임직원 노트북에서 API 키가 새는 것

사고는 압도적으로 런타임에서 난다. 그런데 대부분의 조직이 개발 도구 관리 제품만 사고 “통제했다”고 생각한다. 요청 조건이 “3사를 임직원이 골라 쓴다” 이므로, 단일 클라우드 벤더의 에이전트 플랫폼은 구조적으로 맞지 않는다.

03 실제로 터지는 위험 6가지

솔루션 선정 기준

솔루션은 “좋아 보이는 것”이 아니라 **이 6개를 각각 누가 막는지**로 고른다.

	위험	시나리오	막는 지점
R1	데이터 유출	CS 에이전트를 만들다 고객 주소·연락처 CSV 를 그대로 외부 모델에 붙여넣음	① ②
R2	자격증명 확산	동작시키려고 받은 운영 DB 계정을 코드에 하드코딩, 개인 노트북·Slack 에 잔존	① ③
R3	과잉 권한	“조회만” 만들려던 에이전트가 WMS 쓰기 권한까지 가진 계정으로 붙어 있음	③
R4	프롬프트 인젝션	고객 문의 본문에 숨어있는 지시를 에이전트가 따라 환불 API 를 호출	③
R5	공급망	모델이 지어낸 없는 패키지명을 설치 → 동명의 악성 패키지가 이미 선점되어 있음	① ④
R6	유령 에이전트 · 비용	만든 사람이 부서 이동, 아무도 모르는 채 6개월간 돌며 매달 과금	② ④

04 기술로 100% 막을 수 없는 것

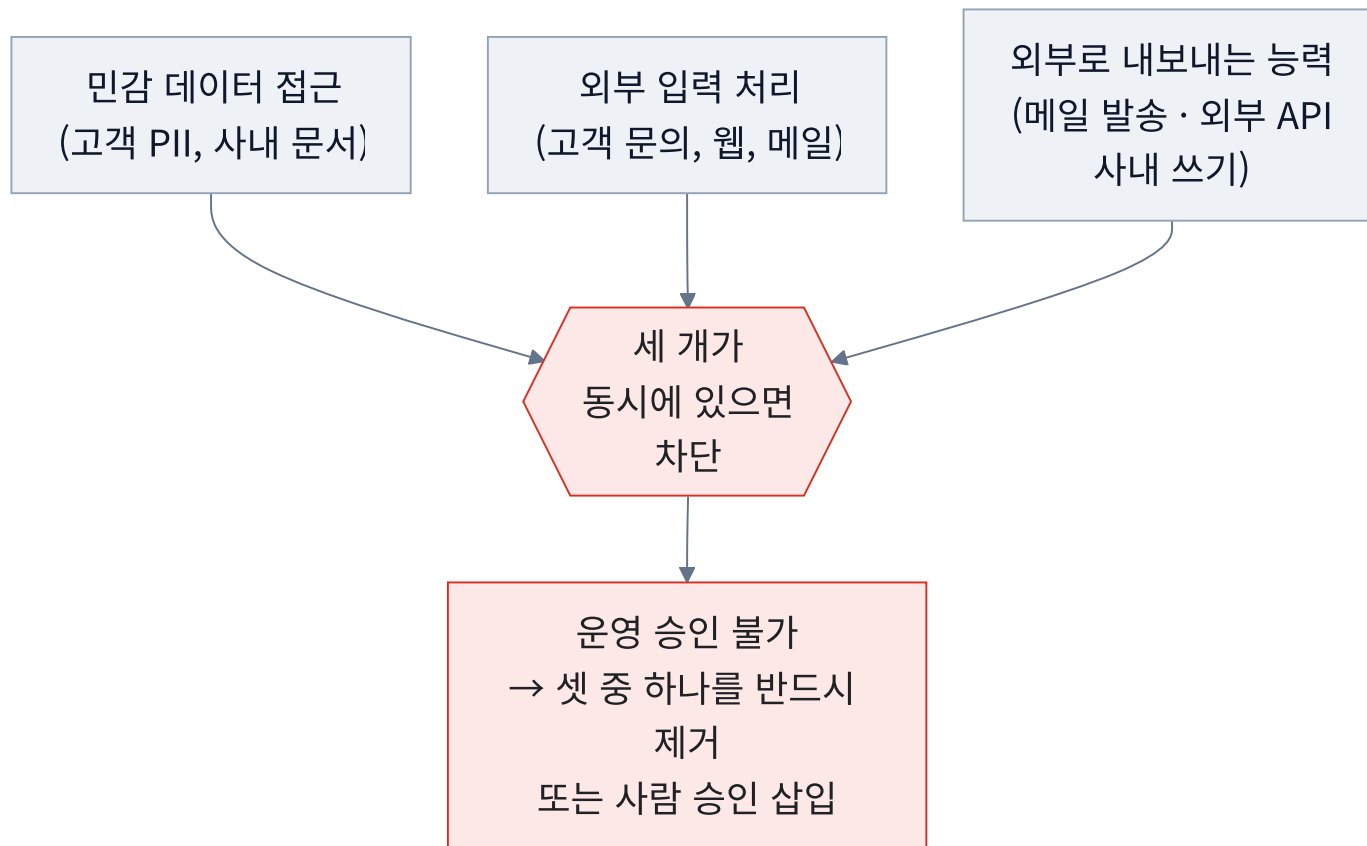
R4 프롬프트 인젝션

프롬프트 인젝션은 **현재 완전 방어 수단이 없다.**

그래서 기술이 아니라 **구조**로 막아야 한다.

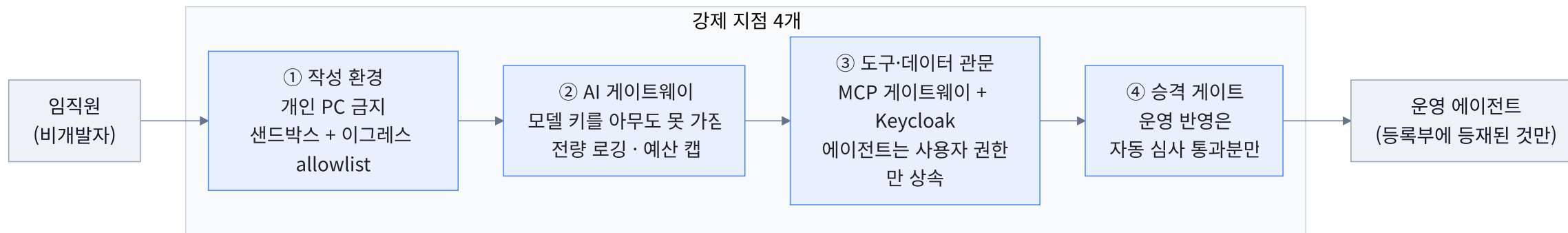
- 세 요소가 **한 에이전트에 동시에** 있으면 언제든 털린다고 봐야 한다
- 해제 조건은 **셋 중 하나 제거**, 또는 **사람 승인 단계 삽입**
- 이 판정은 **자동화할 수 있다** — 에이전트 등록부의 선언값으로 CI가 기계적으로 차단

사람 심사에 의존하면 반드시 뚫린다. 자동 판정으로 만들어야 한다.



05 해법 — 강제 지점 4개

플랫폼이 아니라 길목

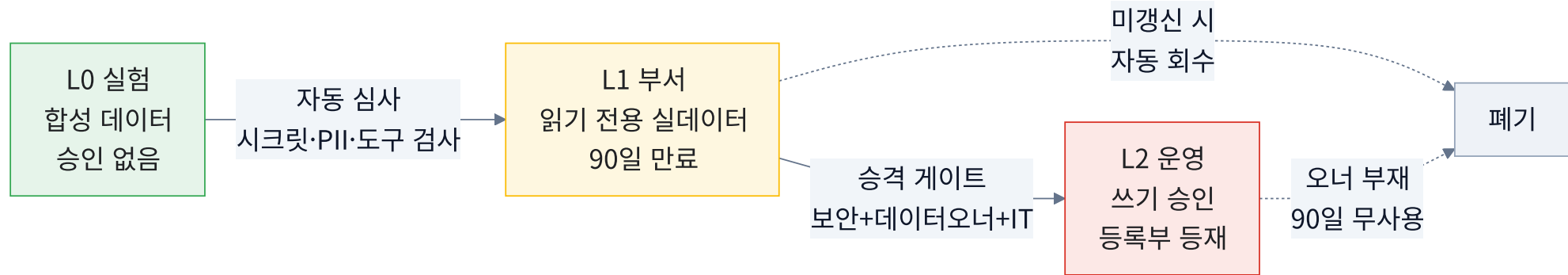


강제 지점	핵심 솔루션 (권고)	이것이 막는 사고
① 작성 환경	원격 워크스페이스(Coder) + devcontainer + 도메인 allowlist	소스·데이터가 개인 PC/외부로 나감, 임의 스크립트 실행
② AI 게이트웨이	LiteLLM Proxy 자체호스팅	API 키 유출·전용, 비용 폭주, 금지 모델, 무기록 프롬프트
③ 도구·데이터 관문	MCP 게이트웨이 + 기존 Keycloak + Vault	과잉 권한, 인젝션에 의한 도구 오남용, PII 유출
④ 승격 게이트	템플릿 레포 + 자동심사 CI + 에이전트 등록부	미검증 코드의 운영 반영, 유령 에이전트, 규제 대응 불가

이 4개만 통과하도록 만들면 임직원이 어떤 도구로 무엇을 만들든 통제가 성립한다. 반대로 그 외에는 통제하지 않는다 — 어떤 모델을 쓸지, 어떤 프롬프트를 쓸지, 어떻게 만들지는 전부 임직원의 자유다.

06 3-레인 모델

통제 강도를 등급으로 나눈다

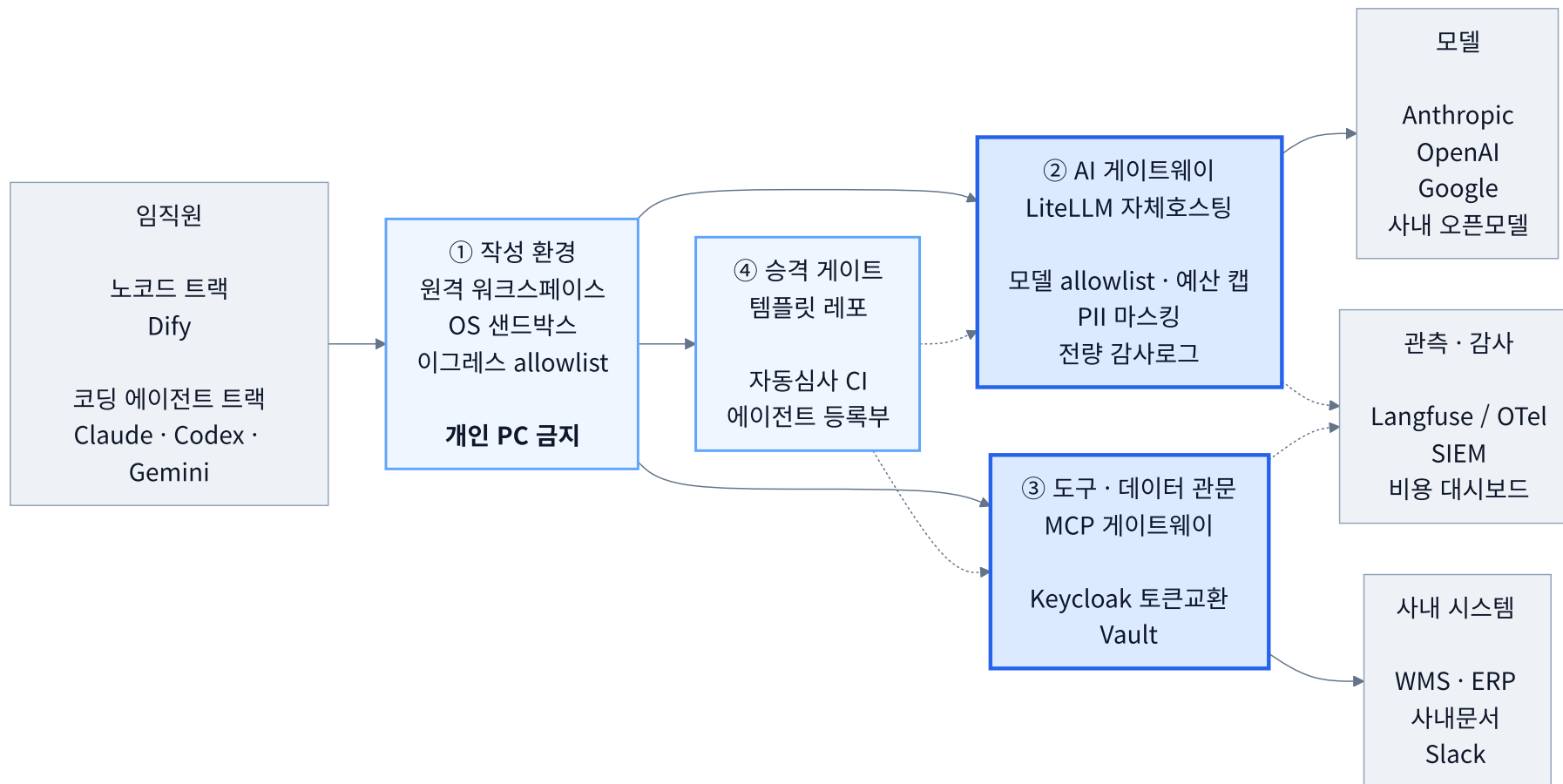


	L0 실험	L1 부서	L2 운영
데이터	합성·마스킹만 (실데이터 금지)	실데이터 읽기 전용	실데이터 (범위 승인)
쓰기 권한	없음	없음	승인된 API 만, 건별 한도
승인	없음 (즉시 시작)	팀장 1인	보안 + 데이터오너 + IT
리드타임	0일	1일 이내	2주 이내

L0의 리드타임 0일이 이 설계의 핵심이다. 실험 단계에 승인을 걸면 임직원은 개인 ChatGPT 계정으로 도망간다(= 통제 불가능한 새도 AI). L0을 충분히 쓸 만하게 만들어 두는 것이 가장 효과적인 보안 대책이다.

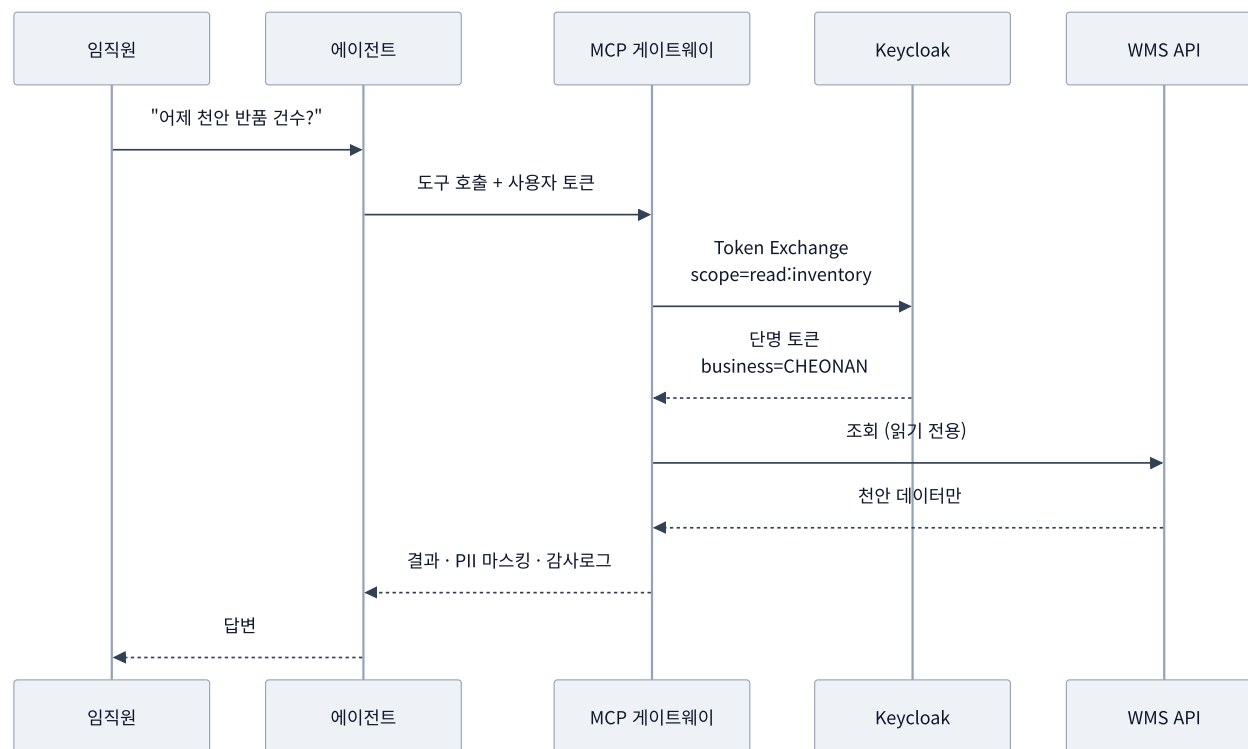
07 레퍼런스 아키텍처

파란색 = 반드시 통과해야 하는 관문



구축 순서 — ② AI 게이트웨이를 가장 먼저 세운다. 2주 만에 “누가 무엇을 얼마나 쓰는지” 가시성이 생기고, 이후 모든 통제의 기반이 된다.

08 핵심 설계 — 에이전트는 자기 권한이 없다



에이전트에 **고정 계정**을 주면 인젝션에 당했을 때 **그 계정 권한 전부**가 공격자 손에 들어간다.

대신 **요청한 사람의 토큰을 교환**해 그 사람 권한 만큼만 빌려준다. 축소만 가능하고 확대는 불가능하다.

- 인젝션에 당해도 **피해 상한이 사용자 권한으로 고정**된다
- 운영 중인 **business 클레임**(ITGRIMS/CHEONAN 분리)이 에이전트에도 그대로 적용 — 별도 권한 체계 불필요
- **퇴사자 계정 비활성화 = 에이전트 즉시 무력화**. 유령 에이전트 문제의 절반이 자동 해결

계층	후보	권고	선정 이유
노코드 트랙	Dify · n8n · Flowise	Dify 자체호스팅	RBAC·SSO·감사로그 기본 탑재, 데이터가 사내에 남음
코딩 에이전트	Claude Code · Codex · Gemini CLI	3사 모두 허용	도구는 자유, 정책은 하나 — 같은 게이트웨이·같은 샌드박스 통과
작성 샌드박스	내장 샌드박스 · devcontainer · 원격 워크스페이스 · VM	devcontainer + 원격 워크스페이스	내장 Bash 샌드박스만으로는 불충분(MCP·훅이 호스트에서 실행됨)
런타임 샌드박스	Docker · gVisor · Firecracker · E2B · Daytona	gVisor RuntimeClass	기존 K8s 에 추가만 하면 됨. PII 워크로드가 외부 SaaS 로 안 나감
AI 게이트웨이	LiteLLM · Portkey · Kong · Cloudflare	LiteLLM 자체호스팅	100+ 모델, 가상카·예산·팀 관리, 로그가 사내에 남음
아이덴티티	신규 IAM · 기존 Keycloak	기존 Keycloak	새로 살 필요 없음. Token Exchange 로 권한 상속
관측·감사	Langfuse · Phoenix · LangSmith	Langfuse + OTel	자체호스팅 가능, 게이트웨이 콜백으로 바로 연동

이그레스(egress) allowlist 가 샌드박스의 본체다. 파일 격리보다 이쪽이 중요하다. 기본 차단 후 AI 게이트웨이 · 패키지 프록시 · Git · MCP 게이트웨이(모두 사내) 만 연다. 모델 벤더 API 직결도 차단한다.

10 도입안 3가지 비교

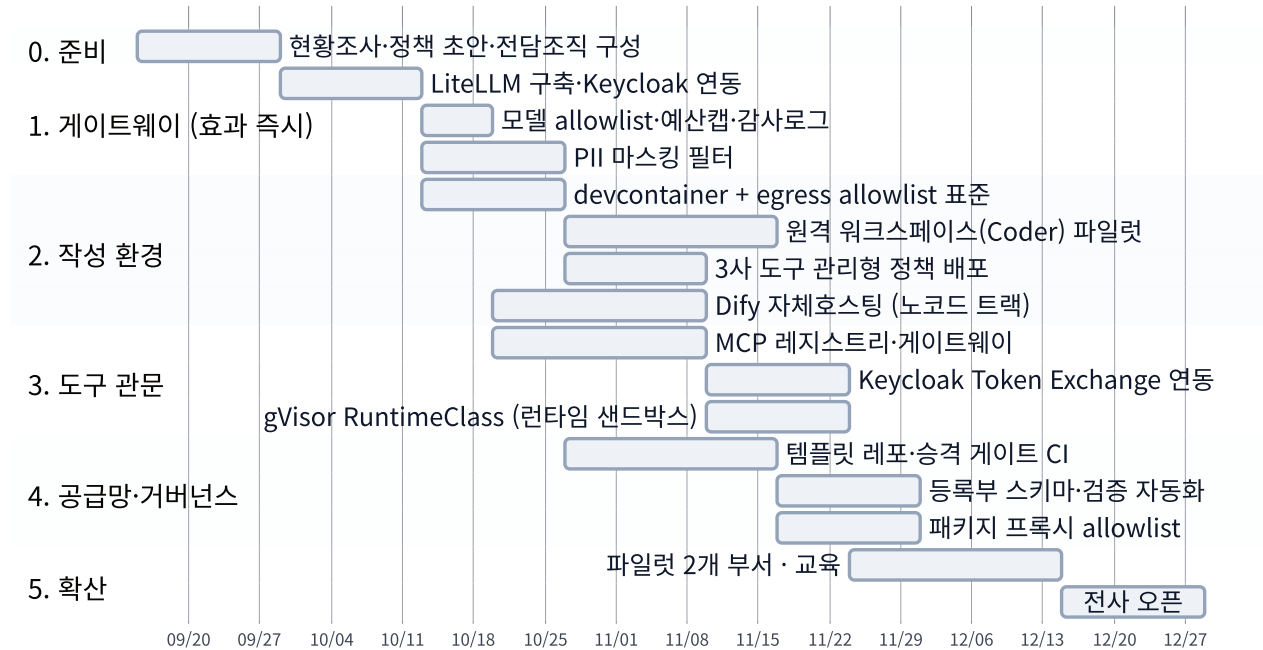
권고: 안 B

	안 A · SaaS 최속	안 B · 자체호스팅 하이브리드	안 C · 단일 클라우드 통합
구성	Claude/ChatGPT Enterprise + 매니지드 GW + E2B	원격 워크스페이스 + LiteLLM + Dify + MCP GW + Keycloak + K8s(gVisor)	Bedrock AgentCore / Gemini Enterprise / Foundry·Agent365
기간	4~6주	10~14주	8~12주
운영 인력	0.5명	1.5~2명	1명
데이터 위치	상당수 외부	전량 사내	해당 클라우드
3사 모델 자유	제한적	완전 자유	제한적 (자사 우선)
락인	벤더별 분산	낮음	높음
Keycloak 활용	부분	완전	부분 (IdP 연동만)

권고 — 안 B 로 가되, 안 A 축소판으로 8주 먼저 검증한다. 1단계(0~8주) 합성 데이터만·2개 부서·20명 PoC → 2단계(6~16주) 안 B 골격 구축 → 3단계 이관·확대. **1단계에 실데이터를 넣지 않는 것이 조건이다.** 지키면 PoC 는 순수한 학습이 되고, 지키지 않으면 되돌릴 수 없는 부채가 된다.

11 12주 로드맵

안 B 골격



— 0~2주 · 준비

현황조사 · AI 사용정책 초안 · **전담조직 구성**

— 2~5주 · 게이트웨이 **효과 즉시**

LiteLLM 구축 → Keycloak 연동 → 모델 allowlist · 예산캡 · 감사로그 · PII 마스킹

— 4~9주 · 작성 환경

devcontainer 표준 · 원격 워크스페이스 파일럿 · 3사 관리형 정책 배포 · Dify

— 5~10주 · 도구 관문

MCP 레지스트리·게이트웨이 · Token Exchange · gVisor

— 4~9주 · 공급망

템플릿 레포 · 승격 게이트 CI · 등록부 검증 · 패키지 프록시

— 10~15주 · 확산

2개 부서 파일럿 · 교육 → 전사 오픈

12 거버넌스 — 기술이 아닌 부분

없으면 반년 안에 우회당한다

에이전트 등록부

모든 에이전트가 레포 안 `agent.yaml` 로 **자기 자신을 선언**하고 CI 가 검증한다. 선언과 코드가 불일치하면 배포 차단.
사람이 관리하는 엑셀 대장은 반드시 실패한다.

오너십 · 수명주기

오너는 IT 가 아니라 **업무 담당 부서**. `review_due` 만료 시 자동 비활성. 90일 무사용 자동 회수. 분기 감사로 등록부 대 실제 배포 대조.

교육 · 자격

L1 이상은 2~3시간 교육 이수 후 접근. 데이터 등급 · 인젝션 · 시크릿 · 등록부 작성법.
L0 는 **교육 없이 즉시**.

AI 기본법 대응 — 2026-01-22 시행. 위 산출물이 그대로 근거자료가 된다.

법상 요구	대응하는 것
투명성 (생성물 표시·사전 고지)	응답 템플릿에 AI 생성 고지 삽입 — 등록부 <code>ai_disclosure</code> 로 강제
안전성 확보 · 위험관리	3-레인 + 승격 게이트 + 도구 등급(<code>read/write/external_send</code>)
기록 보관 · 설명 의무	게이트웨이 전량 감사 로그 + Langfuse 추적
고영향 AI 판단	등록부 <code>high_impact_use_case</code> 로 후보 식별 → 법무 검토로 확정

13 흔히 실패하는 지점

무너지는 이유는 기술이 아니다

실패 패턴	결과	대응
통제를 먼저, 편의는 나중에	개인 계정으로 이탈 → 통제 불가능한 새도 AI. 이전보다 나빠진다	L0 를 즉시·무승인 제공. 승인은 데이터가 개입할 때만
PoC 에 실데이터 투입	되돌릴 수 없는 부채, 규제 노출	1단계는 합성 데이터만. 예외 없음
“다 되는 제품” 탐색	6개월 벤더 비교하다 아무것도 못 함	초크포인트별 최선의 도구. 게이트웨이부터 2주 안에 시작
전담 인력 없이 착수	6개월 뒤 방치	플랫폼팀 1.5~2명 확보가 전제조건
비개발자에게 코드 리뷰 요구	병목 → 우회	사람 리뷰 대신 자동 심사 + 레인 제한. 사람은 L2 만
에이전트에 고정 계정 부여	과잉 권한 + 인젝션 피해 확대	Token Exchange 로 사용자 권한 상속

제안 구체화를 위해 정해져야 할 것

- **전담 인력** — 플랫폼팀 1.5~2명 확보 가능 여부 **가장 중요**
- **대상 규모** — 1차 오픈 인원·부서 (20명/2개 부서 권고)
- **데이터 등급 기준** — 반품·배송 데이터 중 어디까지가 PII 이고 어디까지 L1 읽기 허용인지
- **인프라 방향** — 기존 K8s 재활용 가능 여부, 클라우드/온프레임 구성
- **모델 계약** — 3사 기업 계약 여부 (학습 미사용·데이터 보존 조건)
- **규제 범위** — 채용·인사·평가 용도 허용 여부 (고영향 AI 소지)

결정과 무관하게 지금 착수 가능한 것

1. AI 게이트웨이 (2주)

LiteLLM 구축 + Keycloak 연동. 어떤 안을 택하든 **버려지지 않는** 투자이며, 2주 만에 사용 현황 가시성이 생긴다.

2. AI 사용 정책 개정

“개인 계정으로 사내 데이터를 외부 AI 에 입력 금지” 명문화. 단, **L0 제공과 동시에** 해야 실효가 있다.

3. Keycloak 토큰 교환 검증

빈 인스턴스에서 Token Exchange 재현. 버전별로 지원 형태가 다르므로 **설계 확정 전 확인 필요**.